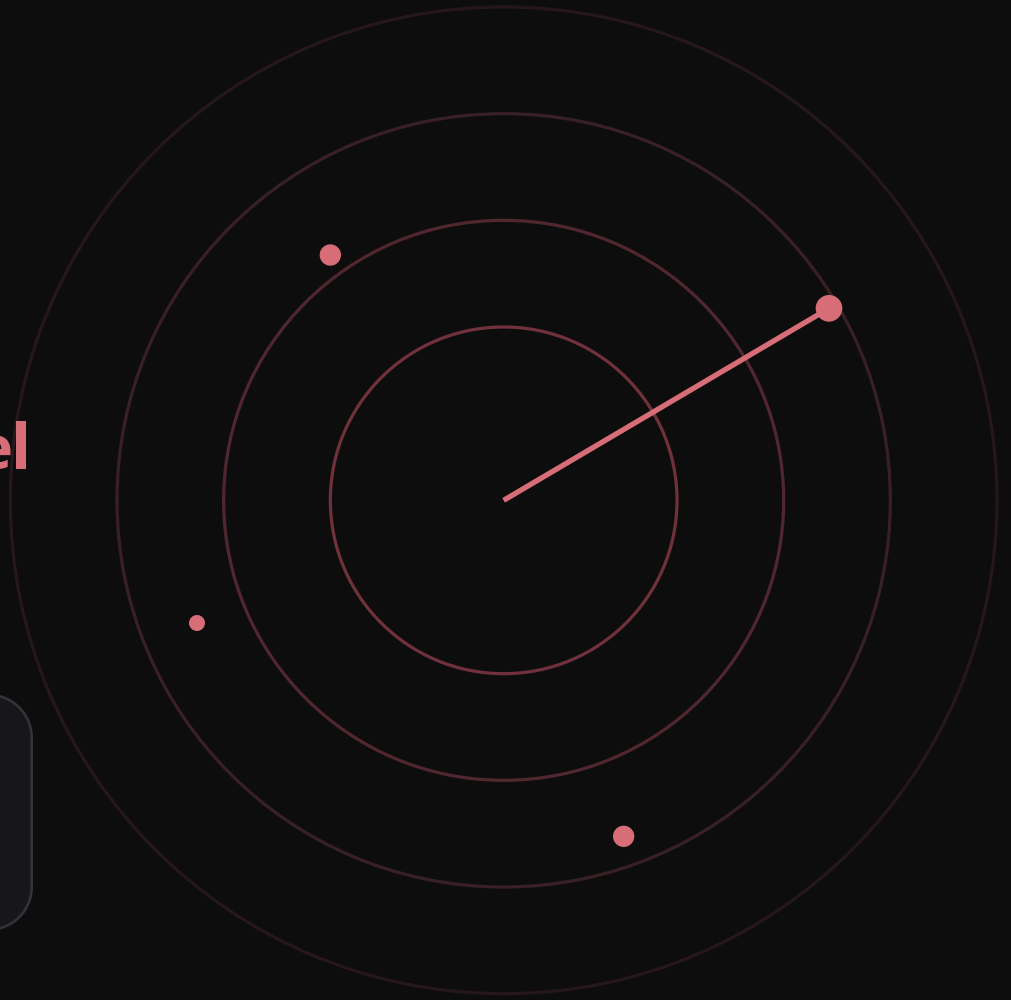
PHISH RADAR AI

SECURE ACCESS

ระบบคัดกรอง URL และเว็บไซต์เสียง

ด้วย Layered Evidence + L1 Logistic Risk Model

Chrome Extension / Web App / FastAPI / MySQL / Qwen



แนวคิดหลัก

ตรวจจับก่อนผู้ใช้กรอก Password หรือ OTP พร้อมอธิบายเหตุผล

ออกแบบให้ทำงานแบบ local ได้ และต่อยอดสู่ระบบ AI ที่วัดผลได้

เอกสารนำเสนออาจารย์ / 24 กรกฎาคม 2026

01 / PROBLEM

ปัญหาและวัตถุประสงค์

ผู้ใช้มักตัดสินใจจากหน้าตาและข้อความลิงก์ ก่อนเห็นโดเมนปลายทางจริง

ปัญหาที่ต้องแก้

- Phishing ใช้โดเมนคล้ายแบรนด์ คำว่า login/verify และหน้าเก็บรหัสผ่านเพื่อสร้างความน่าเชื่อถือ
- การเตือนหลังผู้ใช้เข้าเว็บแล้วอาจช้าเกินไป โดยเฉพาะเมื่อมีการขอ Password หรือ OTP
- ระบบที่บล็อกอย่างเดียวอธิบายไม่ได้ ทำให้ผู้ใช้ไม่เข้าใจและเกิด False Positive ได้ง่าย

วัตถุประสงค์

01 ตรวจลิงก์และบริบทหน้าเว็บก่อนเข้าถึง

02 ผสม RuleScore 40% กับ MLScore 60% และคุม FPR

03 เก็บบัญชี อุปกรณ์ Session และประวัติอย่างปลอดภัย

04 ให้ LLM อธิบายผล แต่ไม่อนุญาตให้เปลี่ยนคำตัดสิน

02 / ARCHITECTURE

สถาปัตยกรรมระบบแบบหลายชั้น

Extension ยังตรวจแบบ local ได้เมือ Backend หรือ LLM ไม่พร้อม

Chrome Extension

สแกน URL / DOM / Form
ดัก navigation ก่อนเปิดเว็บ

→

Web App

Login / Dashboard
History / Settings / Report

→

FastAPI Backend

Predict / Auth / History
LLM explanation / Feedback

→

MySQL + Model

Users / Devices / Sessions
SearchHistory / model.pkl

เส้นทางข้อมูลทีออกแบบให้ลดความเสียหาย

Rule-based local

ใช้ได้ทันทีโดยไม่ต้องส่ง URL ออกนอกเครือง

Risk Model API

L1 Logistic model และ policy ถูกโหลดจาก Backend

LLM optional

สร้างคำอธิบายเท่านั้น หากไม่พร้อมใช้ข้อความสำรอง

SQL security

เก็บ PasswordHash และ TokenHash ไม่เก็บ secret ดิบ

03 / DETECTION FLOW

ตรวจจับก่อนเข้าถึง และอธิบายได้

ระบบรวมสัญญาณจาก URL หน้าเว็บ และนโยบายที่ผ่านการประเมิน

1

รับ URL / หน้าเว็บ

navigation, link, form, clipboard หรือ QR

→

2

คำนวณ RuleScore

URL structure, brand, redirect, DOM context

→

3

คำนวณ MLScore

sigmoid probability จาก L1 Logistic

→

4

คำนวณ FinalScore

Rule 40% + ML 60% แล้วกำหนด decision

→

5

ตอบสนอง

อนุญาต / เตือน / บันทึก และอธิบายเหตุผล

ตัวอย่างสัญญาณที่อธิบายให้ผู้ใช้เห็นได้

- HTTP บนหน้า Login
- Subdomain ซ้อน
- Brand impersonation
- Punycode / Homoglyph
- Redirect ซ่อนปลายทาง
- Password / OTP form
- ลิงก์ย่อ / ไฟล์เสียง
- ข้อความลิงก์ไม่ตรง URL

04 / DATASET

ชุดข้อมูลสมดุลและป้องกันข้อมูลรั่วไหล

ข้อมูลถูก parse เป็นข้อความเท่านั้น ระบบสร้าง Dataset ไม่เข้าเยี่ยมชม URL ใน feed

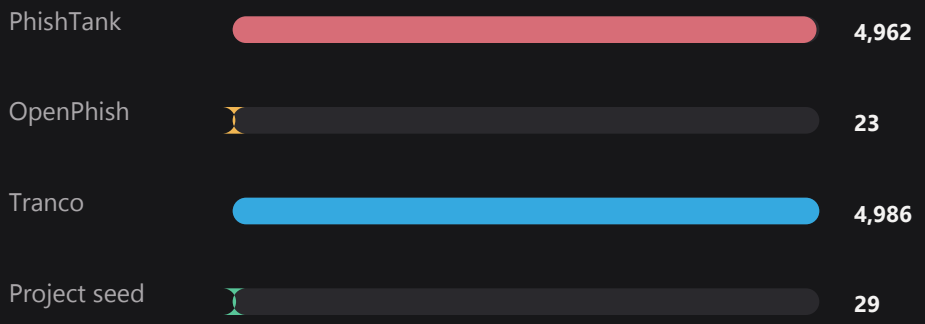
10,000
URL ทั้งหมด

5,000 / 5,000
Phishing / Legitimate

7,933
Unique hostnames

42
Random seed

แหล่งข้อมูล



หลักการเตรียมข้อมูล

- Normalize และลบ URL ซ้ำแบบ case-insensitive
- ตัด hostname ที่มี label conflict ออกจากฝั่ง legitimate
- Group ตาม hostname เพื่อไม่ให้โดเมนเดียวกันรั่วข้าม fold
- บันทึก SHA-256 ของ Dataset, feed และ analyzer เพื่อทำซ้ำได้

05 / EXPERIMENT

Grouped Evaluation และ FPR-controlled Policy

แยก grouped holdout ก่อนเลือกโมเดลและ threshold เพื่อลดข้อมูลรั่วไหล

A

Grouped holdout

กันข้อมูลทดสอบก่อน
Group = hostname

→

B

StratifiedGroupKFold

5 folds บน development
สร้าง OOF probability

→

C

L1 Logistic

เลือก C จาก Log loss
Brier และ ROC-AUC

→

D

Two thresholds

warn FPR <= 1%
block FPR <= 0.1%

กติกาเลือก Policy

บังคับ Wilson upper bound 95% ของ FPR ไม่เกินเพดาน แล้วเลือก Recall สูงสุด

Threshold ใช้ development OOF เท่านั้น ส่วน grouped holdout ใช้รายงานผลอิสระ

06 / LEARNED RISK

FinalScore = 0.40(RuleScore) + 0.60(MLScore)

MLScore เรียนจากข้อมูล ส่วน RuleScore มาจากกฎและบริบทใน browser

FinalScore

0.40 x RuleScore + 0.60 x MLScore

L1 Logistic Regression จาก URL features

Decision policy

warn >= 0.35

block >= 0.80

Rule evidence

อธิบายสัญญาณได้
และทำงาน local

→

URL features

lexical และ host clues
schema มี version

→

FinalScore

RuleScore 40%
MLScore 60%

→

Decision

allow / warn / block
จาก model policy

Development OOF เทียบ Independent Grouped Holdout

รายงานผลจริงรวมข้อจำกัด ไม่ใช้ holdout เพื่อปรับค่าโมเดลหรือ threshold

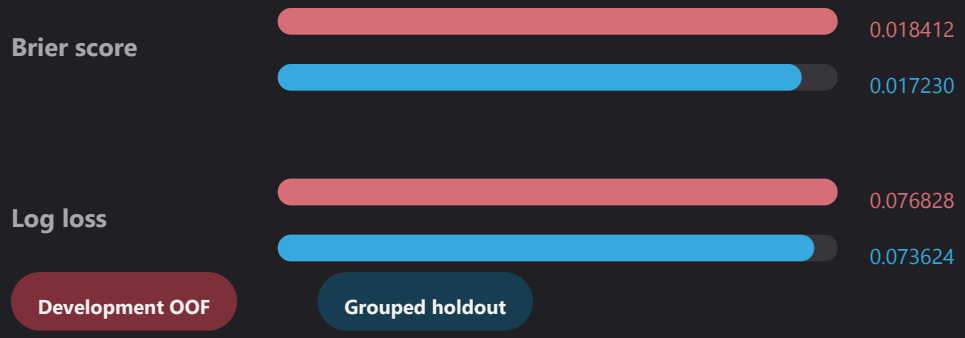
99.13%	97.04%	98.07%	99.19%	1.12%
Precision	Recall	F1	ROC-AUC	FPR

Confusion Matrix

	Predicted
TN 972	FP 11
FN 38	TP 1,247

Actual

Probability Quality



ระบบสมาชิกและฐานข้อมูลที่ไม่เก็บ Secret ดิบ

User และ Admin ใช้หน้า Login เดียวกัน แต่บัญชีใหม่เริ่มต้นเป็น Role = user เสมอ

Users

UserID / Username / Email / PasswordHash / Role / IsActive

Password: Argon2id hash

UserDevices

DeviceName / DeviceKeyHash / Trusted / Revoked / LastSeenAt

Device token: SHA-256 hash

Sessions

UserID / UserDeviceID / TokenHash / ExpiresAt / RevokedAt

Browser session: HttpOnly cookie

SearchHistory

URL ที่ sanitize / RiskScore/Decision / Model/Policy version / Device / CreatedAt

Default retention: 90 วัน

09 / PRIVACY

ประวัติการค้นหาแบบ Account และ Privacy Mode

ระบบแยกเส้นทางข้อมูลตามความต้องการของผู้ใช้

Account history

- ผูกข้อมูลกับ UserID และ UserDeviceID จาก Session
- ตัด credentials, query string และ fragment ก่อนจัดเก็บ URL
- เก็บ SHA-256 ของ URL ต้นฉบับเพื่อ correlation
- เก็บ Rule evidence, RiskScore, decision, thresholds และ model/policy version
- ผู้ใช้ล้างประวัติหรือส่งออก JSON/CSV ได้

Privacy Mode

- วิเคราะห์ใน Browser และไม่ส่ง URL ไป Backend/LLM
- เก็บประวัติเฉพาะ localStorage ภายใต้บัญชีบนเครื่องนั้น
- ปิด Qwen explanation และ ML cloud assist โดยอัตโนมัติ
- Rule-based protection และคำเตือน local ยังทำงานต่อ

หลักการ

ผู้ใช้เป็นผู้เลือกระดับการส่งข้อมูล ไม่ใช่ระบบเลือกแทน

Qwen เป็นผู้ช่วยอธิบาย ไม่ใช่ผู้ตัดสิน

RiskScore และ decision ต้องให้ผลเดิม แม้ LLM ปิดหรือใช้งานไม่ได้

ค่าเริ่มต้น

Qwen3:4b ผ่าน Ollama

ทำงาน local ลดการส่งข้อมูลออกนอกเครื่อง
และยังใช้ข้อความ fallback ได้เมื่อโมเดลไม่พร้อม

ตัวเลือกเปรียบเทียบ

OpenAI API (optional)

เหมาะสำหรับเปรียบเทียบคุณภาพและ latency
แต่ต้องใช้อินเทอร์เน็ต ค่า API และนโยบายข้อมูลที่ชัดเจน

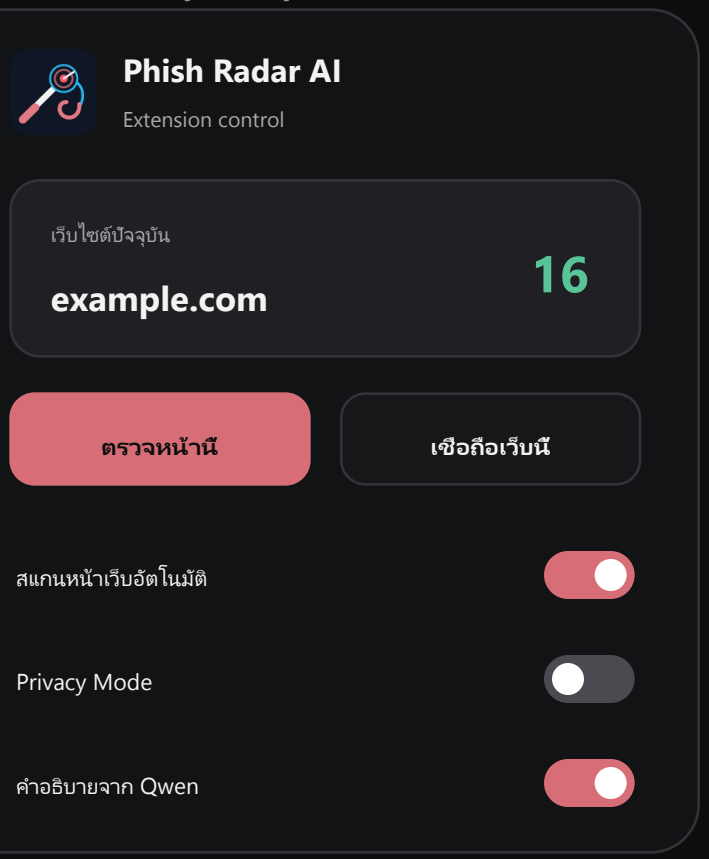
Benchmark ที่ต้องทำต่อ

- คุณภาพคำอธิบาย 1-5
- JSON/schema pass rate
- Hallucination rate
- Latency p50/p95
- Cloud cost หรือ RAM/VRAM

สถานะปัจจุบัน: มีแผนทดลองแล้ว แต่ยังไม่มีผล benchmark บนเครื่องนี้

สิ่งที่พัฒนาเสร็จและลำดับการสาธิต

รายการจากอาจารย์ถูกนำมาผูกกับโค้ดและเอกสารจริงในโปรเจกต์



สถานะงานตามรายการ

01	แหล่งอ้างอิงและวิธีคำนวณความเสี่ยง	เสร็จ
02	User Login และการเก็บข้อมูลผู้ใช้	เสร็จ
03	ประวัติการค้นหาแยกตาม User/Device	เสร็จ
04	คำสั่งเริ่มระบบด้วย Git Bash	เสร็จ
05	เปรียบเทียบ LLM และตั้ง Qwen เป็นค่าเริ่มต้น	ออกแบบแล้ว

คำสั่ง Demo: `./migrate-db.sh` แล้ว `./start-demo.sh`

ข้อจำกัดและงานที่ควรทำต่อ

เน้นลดช่องว่างระหว่างผล Cross-validation กับการใช้งานจริง

ข้อจำกัดปัจจุบัน

- Dataset snapshot เดียวอาจไม่สะท้อนแคมเปญ phishing ในอนาคต
- ยังไม่มี time-split holdout และ traffic จริงที่แยกจากการเลือก policy
- Rule-based และ URL features อาจพลาดหน้าเว็บที่เลียนแบบด้วยภาพหรือ DOM ขั้นสูง
- LLM comparison ยังไม่มีผล benchmark จาก prompt และเครื่องเดียวกัน
- Admin role ยังควรมี API และ audit log แทนการปรับผ่าน SQL โดยตรง

ลำดับพัฒนาต่อ

1. **External/time-split evaluation**
   ยืนยัน Risk Model และ thresholds กับข้อมูลใหม่
2. **Drift monitoring + retraining**
   ติดตาม FPR/Recall และ version Dataset/Model
3. **LLM benchmark**
   วัดคุณภาพ Hallucination และ latency อย่างยุติธรรม
4. **Admin API + audit log**
   จัดการ Role, Account และเหตุการณ์สำคัญ
5. **Controlled deployment**
   HTTPS, secret management, backup และ monitoring

13 / DEFENSE NOTES

คำถามทีคาดว่าจะได้รับ

คำตอบสั้นควรผูกกับหลักฐานในผลทดลองและข้อจำกัดของระบบ

ทำไมใช้ Rule 40% และ ML 60%?

เป็น policy คงทีของการทดลอง โดย ML มีน้ำหนักหลัก และเลือก threshold ใหม่บน FinalScore ภายใต้เพดาน FPR

ทำไมใช้ Logistic Regression?

sigmoid ให้ probability โดยตรง, L1 ช่วยเลือก feature และยังตรวจ Brier/Log loss บน grouped holdout

ระบบเก็บรหัสผ่านหรือไม่?

ไม่เก็บรหัสผ่านจริง เก็บ Argon2id PasswordHash และเก็บ Session/Device token เฉพาะ SHA-256 hash

Qwen เป็นตัวตัดสิน Phishing หรือไม่?

ไม่ใช่ LLM มีหน้าทีอธิบาย RiskScore, decision และ evidence เท่านั้น ปิด LLM แล้วผลต้องไม่เปลียน

ผลนีพร้อมใช้ Production หรือยัง?

ยัง ต้องเพิม time-split holdout, traffic จริง, drift monitoring, audit log และ deployment controls

ถ้า Backend ล่มจะเกิดอะไรขึน?

Extension ยังใช้ Rule evidence local และคำเตือนแบบ offline ได้ แต่ Risk Model, Login/History และ LLM จะไม่พร้อม

14 / REFERENCES

แหล่งข้อมูลและงานอ้างอิงหลัก

รายละเอียดการทดลองทั้งหมดอยู่ใน docs/RISK_MODEL_METHODOLOGY_TH.md

Ma, J. et al. (2009)

Beyond Blacklists: Learning to Detect Malicious Web Sites from Suspicious URLs. ACM KDD. https://doi.org/10.1145/1557019.1557153

Xiang, G. et al. (2011)

CANTINA+: A Feature-rich Machine Learning Framework for Detecting Phishing Web Sites. ACM TISSEC. https://doi.org/10.1145/2019599.2019606

Le Pochat, V. et al. (2019)

Tranco: A Research-Oriented Top Sites Ranking Hardened Against Manipulation. NDSS. https://doi.org/10.14722/ndss.2019.23386

Maneriker, P. et al. (2021)

URLTran: Improving Phishing URL Detection Using Transformers. MILCOM / Microsoft Research.

University of Cambridge

Discovering Phishing Dropboxes Using Email Metadata. Used to support multi-source contextual evidence, not the RiskScore formula.

Project evidence

risk_model_evaluation.json, training_urls.manifest.json, SQL migrations 001-004, backend tests and project validation scripts.